

1. Introduction

This report is an incident analysis report based on the analysis of `cw1.pcap`. The pcap file provides evidence and a timeline of the incident. It discusses and identifies which systems were infected, how the infection occurred, and the type of malware involved. Finally, it discusses prevention tools and methods as recommendations to reduce or avoid similar incidents in the future.

2. Methodology

2.1 Tool and Strategy

In the investigation, Zui and Wireshark will be used to review, locate, and identify critical evidence from the pcap file. The third-party source 'virustotal.com' will verify findings from the pcap to confirm results. The drill-down approach and cyber kill chain will be used to identify the timeline, incident trigger, and impact at a broad level.

2.2 Identification of the Infected System

In Zui, the DHCP request can be used to identify the IP, hostname, MAC address, and domain.

Figure 1: DHCP Discover Packet Details in Zui

```
{
  "_path": "dhcp",
  "ts": "2021-09-24T16:43:42.741887Z",
  "uids": [
    {
      "0": "CRiev3UeWP4uSEEu9",
      "1": "CHdZ281znzXV9wql13"
    }
  ],
  "client_addr": "10.9.23.102",
  "server_addr": "10.9.23.5",
  "mac": "00:08:02:1c:47:ae",
  "host_name": "DESKTOP-IOJC6RB",
  "client_fqdn": "DESKTOP-IOJC6RB.goingfortune.com",
  "domain": "goingfortune.com",
  "requested_addr": "10.9.23.102",
  "assigned_addr": "10.9.23.102",
  "lease_time": 7d,
  "client_message": null,
  "server_message": null,
  "msg_types": [
    {
      "0": "REQUEST",
      "1": "ACK"
    }
  ],
  "duration": 681us
}
```

Figure 1 shows the system information as follows:

Client IP: 10.9.23.102
 Server IP: 10.9.23.5
 MAC: 00:08:02:1c:47:ae
 Hostname: DESKTOP-IOJC6RB
 Client FQDN: DESKTOP-IOJC6RB.goingfortune.com
 Domain: goingfortune.com

The IP address belongs to the Class A private IP range, which means that the system is in an enterprise network.

Figure 1.1: Zui Query Results Showing DHCP Session Details

_path	ts	uids	client_addr	server_addr	mac	host_name	client_fqdn	domain	requested_addr	assigned_addr
dhcp	2021-09-24T16:43:42.741887Z	[CRiev3UeWP4uSEEu9, CHdZ281znzXV9wql13]	10.9.23.102	10.9.23.5	00:08:02:1c:47:ae	DESKTOP-IOJC6RB	DESKTOP-IOJC6RB.goingfortune.com	goingfortune.com	10.9.23.102	10.9.23.102

2.3 Determination of Infection Vector

From **Figures 2.1 and 2.2**, the pcap file records range from '2021-09-24T16:43:42.741887Z' to '2021-09-24T17:04:53.048515Z'. In '2021-09-24T16:43:42.741887Z' (**Figure 2.3**), the first alert occurs, where port 80 traffic indicates that the victim may have received a phishing email, clicked a link, and triggered the alert. In that alert, it shows that the system had created a connection with 'SQUIRRELWAFFLE' and received the server response. SquirrelWaffle is typically hidden in a malicious MS Word or Excel file, which is then compressed into a ZIP file (Jayanand, 2025). Therefore, the user likely downloaded a ZIP file, opened the document inside, and triggered the malware, causing the incident.

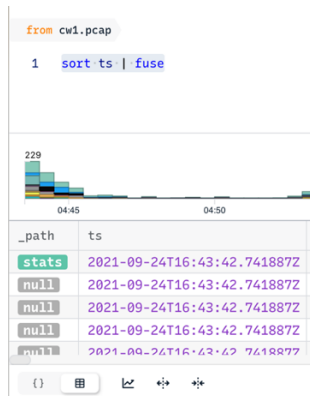


Figure 2.1

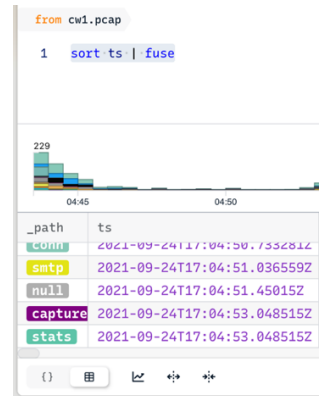


Figure 2.2

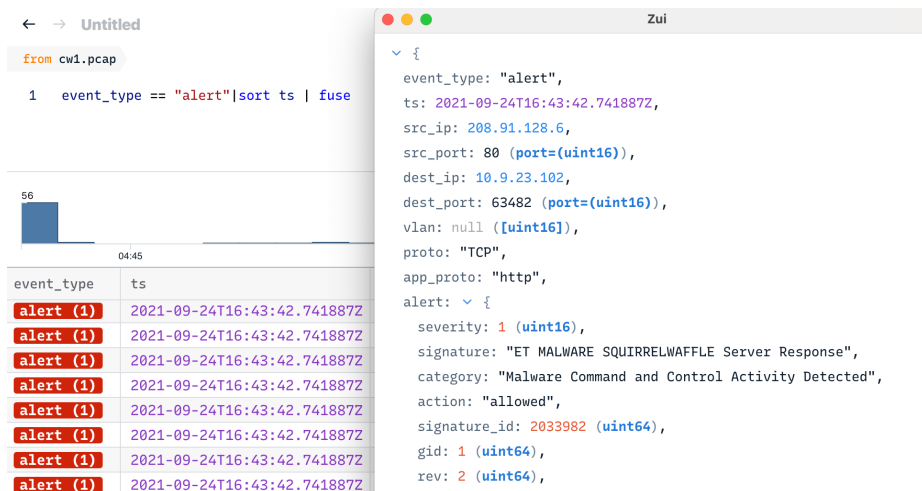


Figure 2.3

3. Result & Analysis

3.1 Initial Access Initial Infection & File Transfer

Since the incident was mainly case by a downloaded file, therefore in **Figure 3.1.1** there are four have been identify download. The first one will be the initial malicious HTTP connection occur time '2021-09-24 16:44:38' the system start download the file and completed in '2021-09-24 16:44:40' **Figure 3.1.2**

File: documents.zip (**Figure 3.1.4**)

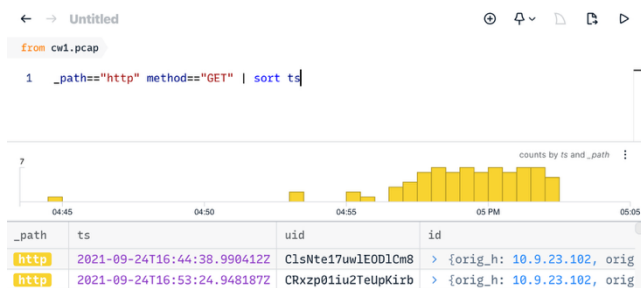


Figure 3.1.1



Figure 3.1.2

In Wireshark, following the TCP stream in **Figures 3.1.3 and 3.1.4** reveals the following:

Malicious File Name: documents.zip
 Hosting Domain: attirenepal.com (85.187.128.24),
 Payload Inside Archive: chart-1530076591.xls
 Hosting Server Software: LiteSpeed
 Server Version: PHP/7.2.34

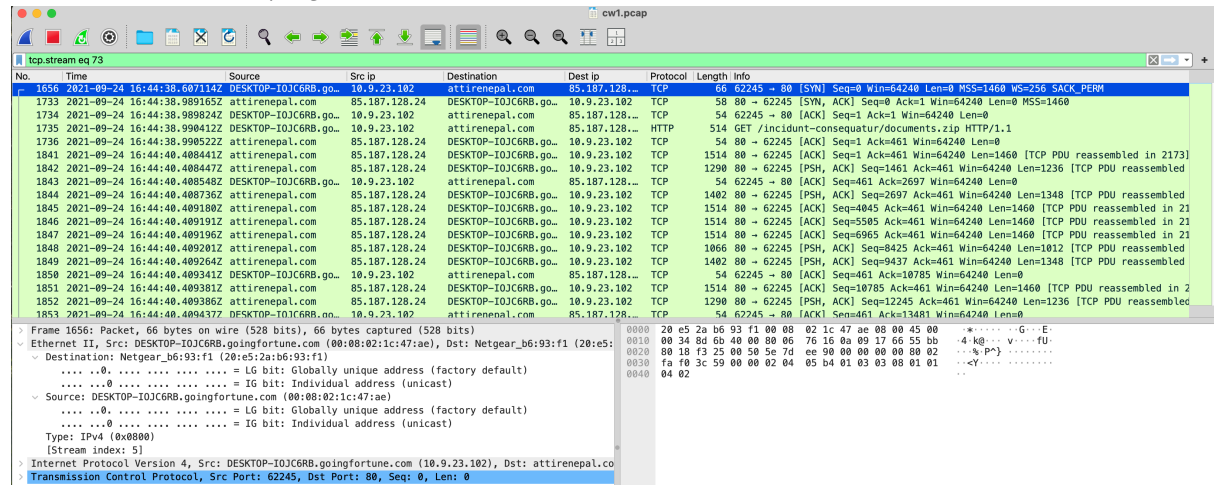


Figure 3.1.3



Figure 3.1.4

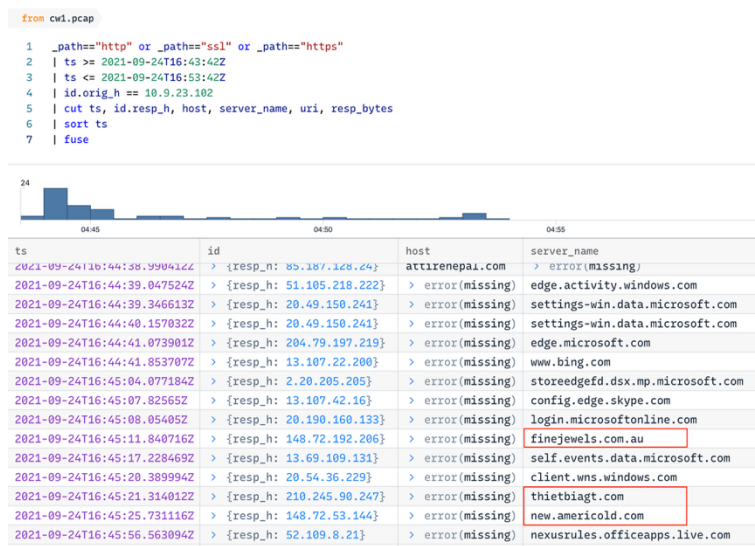


Figure 3.1.5

After confirming that `attirenepal.com` provided `documents.zip` as the initial malicious download, the investigation turned to identifying whether any additional domains were involved in delivering further malicious files. **Figure 3.1.5** shows the results of filtering HTTP, HTTPS, and SSL traffic for the 10 minutes after the first alert. Three suspicious domains were identified:

Domin Name	IP address
finejewels.com.au	148.72.192.206
thietbiagt.com IP	210.245.90.247
new.americold.com	148.72.53.144

3.2 Initial Infection & File Transfer Command and Control (C2) Activity

One of the domains identified has the IP address 148.72.192.206. Therefore, **Figures 3.2.1** and **3.2.2** show that the SSL certificate for this domain was issued by the Certificate Authority (CA) Go Daddy Secure Certificate Authority – G2 (GoDaddy.com, Inc.)

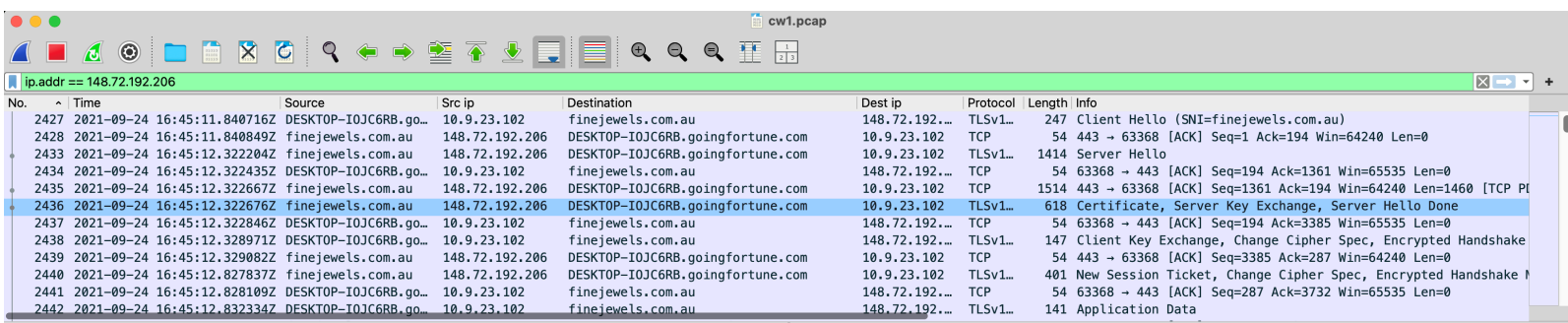


Figure 3.2.1

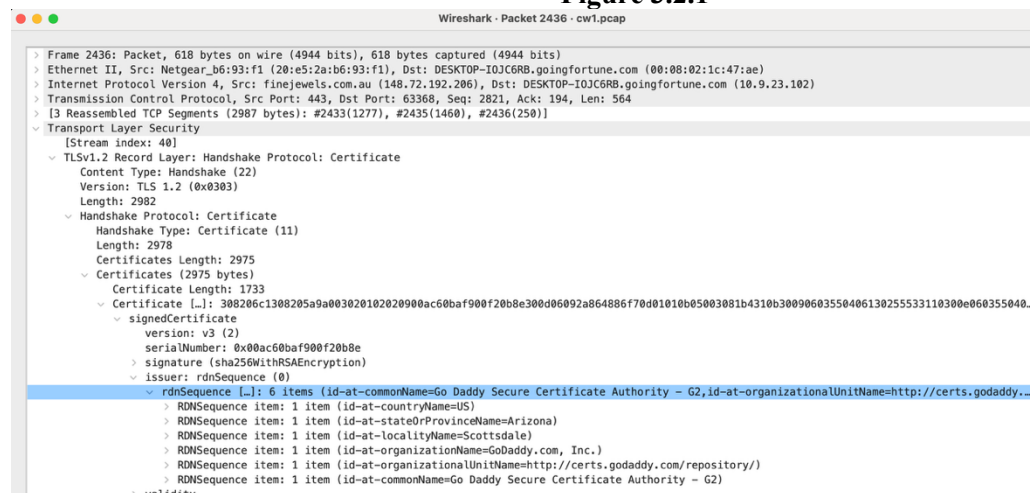


Figure 3.2.2

In the previous section, a malicious file was identified from attirenepal.com (85.187.128.24). After the file download, the suspicious server connected with high frequency and transmitted packets at a high rate per second, as shown in **Figure 3.2.3**. The data from the conversations in Wireshark. These IPs between 85.187.128.23 and 148.72.53.144 were checked with the 'VirusTotal' tool. The red-marked IP is malicious.

	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
1	Address A	Port A	Address B	Port B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	-t	Duration	Bits/s A → B	Bits/s B → A
76	10.9.23.102	59103	51.105.218.222	443	44	14168	74	19	4342	25	9826	56.051971	23.882546	1454	3291	10
77	10.9.23.102	52275	85.187.128.24	80	7	394	75	4	228	3	166	56.074577	24.180024	75	54	0
78	10.9.23.102	56224	51.105.218.222	443	18	8432	76	7	1065	12	7367	56.138454	23.795904	358	2476	4
79	10.9.23.102	56225	20.49.150.241	443	18	7699	77	8	1070	10	6629	56.430027	9.643759	869	5387	6
80	10.9.23.102	56226	20.49.150.241	443	4	232	78	2	120	2	112	56.89672	123.973879	7	7	0
81	10.9.23.102	56227	20.49.150.241	443	20	6297	79	9	1092	11	5205	57.248448	0.991919	8807	41979	6
82	10.9.23.102	65167	204.79.197.219	443	97	82608	80	29	2808	68	79800	58.17185	21.74912	1032	29352	6
83	10.9.23.102	63360	13.107.22.200	443	33	12797	81	15	3470	18	9327	58.946014	20.985389	1322	3555	6
84	10.9.23.5	445	10.9.23.102	63109	2	109	82	1	55	1	54	80.391201	0.000134			1
85	10.9.23.102	63361	2.20.205.205	443	28	11385	83	14	4514	14	6871	81.165306	511.190237	70	107	6
86	10.9.23.102	63362	10.9.23.5	135	12	1804	84	7	898	5	906	84.842585	1.235428	5814	5866	6
87	10.9.23.102	63363	10.9.23.5	49667	24	6994	85	13	4379	11	2615	84.865833	1.212294	28897	17256	16
88	10.9.23.102	63364	13.107.42.16	443	20	8731	86	9	1602	11	7129	84.873003	51.457483	249	1108	6
89	10.9.23.102	63365	10.9.23.5	389	21	7516	87	11	3455	10	4061	84.876422	0.013531	2042716	2401005	11
90	10.9.23.102	63366	10.9.23.5	389	18	6930	88	9	2855	9	4075	84.884868	0.004674			7
91	10.9.23.102	63367	20.190.100.133	443	19	6786	89	10	1514	9	5272	85.131215	0.947335	12785	44520	4
92	10.9.23.102	63368	148.72.192.206	443	437	419529	90	135	7863	302	411666	88.699778	13.571103	4635	242672	6
93	10.9.23.102	63369	13.69.109.131	443	49	23407	91	25	16795	24	6612	94.318721	42.012719	3198	1259	8
94	10.9.23.102	63370	20.54.36.229	443	27	8189	92	12	2645	15	5544	97.476777	1.109791	19066	39964	8
95	10.9.23.102	63371	10.9.23.5	135	10	1512	93	6	832	4	680	97.645192	0.028021	237536	194140	6
96	10.9.23.102	63372	10.9.23.5	49667	22	6743	94	12	4322	10	2421	97.650343	0.022971	1505202	843150	16
97	10.9.23.102	63373	10.9.23.5	389	21	7524	95	11	3463	10	4061	97.659884	0.01096	2527737	2964233	11
98	10.9.23.102	63374	10.9.23.5	389	18	6938	96	9	2863	9	4075	97.666038	0.004405			7
99	10.9.23.102	63375	210.245.90.247	443	218	210396	97	154	3699	154	20657	98.214744	38.116792	776	43352	8
100	10.9.23.102	63376	148.72.53.144	443	388	418379	98	86	5217	302	41362	102.71723	8.228158	4522	358175	6
101	10.9.23.102	63380	92.109.8.21	443	56	47064	99	18	2104	38	44860	133.4775	2.853745	5898	126037	6

Figure 3.2.3

Domin Name	IP address
finejewels.com.au	148.72.192.206
thietbiagt.com IP	210.245.90.247
new.americold.com	148.72.53.144

No.	Time	Source	Src ip	Destination	Dest ip	Protocol	Length	Info
2424	2021-09-24 16:45:11.441665Z	DESKTOP-I0JC6RB.g...	10.9.23.102	finejewels.com.au	148.72.192...	TCP	66	63368 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
2425	2021-09-24 16:45:11.838177Z	finejewels.com.au	148.72.192.206	DESKTOP-I0JC6RB.goingfortune.com	10.9.23.102	TCP	58	443 → 63368 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
2426	2021-09-24 16:45:11.838807Z	DESKTOP-I0JC6RB.g...	10.9.23.102	finejewels.com.au	148.72.192...	TCP	54	63368 → 443 [ACK] Seq=1 Ack=1 Win=65535 Len=0
2427	2021-09-24 16:45:11.840716Z	DESKTOP-I0JC6RB.g...	10.9.23.102	finejewels.com.au	148.72.192...	TLSv1...	247	Client Hello (SNI=finejewels.com.au)
2999	2021-09-24 16:45:20.956631Z	DESKTOP-I0JC6RB.g...	10.9.23.102	thietbiagt.com	210.245.90...	TCP	66	63375 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
3007	2021-09-24 16:45:21.312563Z	thietbiagt.com	210.245.90.247	DESKTOP-I0JC6RB.goingfortune.com	10.9.23.102	TCP	58	443 → 63375 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
3008	2021-09-24 16:45:21.312884Z	DESKTOP-I0JC6RB.g...	10.9.23.102	thietbiagt.com	210.245.90...	TCP	54	63375 → 443 [ACK] Seq=1 Ack=1 Win=65535 Len=0
3009	2021-09-24 16:45:21.314012Z	DESKTOP-I0JC6RB.g...	10.9.23.102	thietbiagt.com	210.245.90...	TLSv1...	244	Client Hello (SNI=thietbiagt.com)
3226	2021-09-24 16:45:25.459117Z	DESKTOP-I0JC6RB.g...	10.9.23.102	new.americold.com	148.72.53.1...	TCP	66	63376 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
3227	2021-09-24 16:45:25.730184Z	new.americold.com	148.72.53.144	DESKTOP-I0JC6RB.goingfortune.com	10.9.23.102	TCP	58	443 → 63376 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460
3228	2021-09-24 16:45:25.730574Z	DESKTOP-I0JC6RB.g...	10.9.23.102	new.americold.com	148.72.53.1...	TCP	54	63376 → 443 [ACK] Seq=1 Ack=1 Win=65535 Len=0
3229	2021-09-24 16:45:25.731116Z	DESKTOP-I0JC6RB.g...	10.9.23.102	new.americold.com	148.72.53.1...	TLSv1...	247	Client Hello (SNI=new.americold.com)

Figure 3.2.4 - 3.2.6

Figure 3.2.7 illustrates the traffic sent from the victim to the external server via an HTTP POST request generated by the beacon at regular intervals.

No.	Time	Source	Src ip	Destination	Dest ip	Protocol	Length	Info
3822	2021-09-24 16:46:15.50882Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	281	POST / HTTP/1.1
3908	2021-09-24 16:46:41.09097Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	285	POST / HTTP/1.1
3996	2021-09-24 16:47:06.571342Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	285	POST / HTTP/1.1
4006	2021-09-24 16:47:31.584352Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	273	POST / HTTP/1.1
4017	2021-09-24 16:47:56.779138Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	293	POST / HTTP/1.1
4027	2021-09-24 16:48:21.058732Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	289	POST / HTTP/1.1
4037	2021-09-24 16:48:46.054572Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	273	POST / HTTP/1.1
4046	2021-09-24 16:49:11.559766Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	285	POST / HTTP/1.1
4090	2021-09-24 16:49:37.414622Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	293	POST / HTTP/1.1
4099	2021-09-24 16:50:02.110462Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	269	POST / HTTP/1.1
4109	2021-09-24 16:50:27.289362Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	269	POST / HTTP/1.1
4118	2021-09-24 16:50:52.261352Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	285	POST / HTTP/1.1
4131	2021-09-24 16:51:17.081882Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	277	POST / HTTP/1.1
4140	2021-09-24 16:51:42.036642Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	265	POST / HTTP/1.1
4150	2021-09-24 16:52:07.751878Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	265	POST / HTTP/1.1
4162	2021-09-24 16:52:32.049662Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	273	POST / HTTP/1.1
4179	2021-09-24 16:52:58.039552Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	289	POST / HTTP/1.1
4207	2021-09-24 16:53:23.176892Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	277	POST / HTTP/1.1
4581	2021-09-24 16:53:48.150362Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	269	POST / HTTP/1.1
4930	2021-09-24 16:54:13.378972Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	289	POST / HTTP/1.1
5208	2021-09-24 16:54:38.381382Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	265	POST / HTTP/1.1
6227	2021-09-24 16:55:03.730992Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	265	POST / HTTP/1.1
6660	2021-09-24 16:55:28.521192Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	297	POST / HTTP/1.1
7188	2021-09-24 16:55:53.484872Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	285	POST / HTTP/1.1
1008	2021-09-24 16:56:19.495342Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	277	POST / HTTP/1.1
1022	2021-09-24 16:56:44.400672Z	DESKTOP-I0JC6RB.g...	10.9.23.102	maldivhost.net	208.91.128.6	HTTP	281	POST / HTTP/1.1
1244	2021-09-24 16:57:18.514192Z	DESKTOP-I0JC6RB.g...	10.9.23.102	survmetr.live	185.186.96...	HTTP	778	POST / HTTP/1.1
1322	2021-09-24 16:57:45.754812Z	DESKTOP-I0JC6RB.g...	10.9.23.102	survmetr.live	185.186.96...	HTTP	826	POST / HTTP/1.1

Figure 3.2.7

By combining Figures 3.2.7 and 3.2.8 and following the stream, we obtained the following findings:



Figure 3.2.8

Post-infection Traffic	
Domain Name:	maldivhost.net
First eleven characters:	zLIisQRWZI9
Length of the first packet	281
Server:	Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

A	B	C	D	E	F
Address A	Port A	Address B	Port B	Packets	Bytes
10.9.23.102	63404	208.91.128.6	80	9	1301
10.9.23.102	63405	90.87.245.154	2222	6	384
10.9.23.102	63406	208.91.128.6	80	9	1317
10.9.23.102	63407	90.87.245.154	2222	6	384
10.9.23.102	63408	90.87.245.154	2222	6	384
10.9.23.102	63409	208.91.128.6	80	12	4816
10.9.23.102	63410	185.125.204.174	8080	255	235170
10.9.23.102	63411	104.83.124.33	80	12	2376
10.9.23.102	63412	104.83.124.33	80	13	2528
10.9.23.102	63413	185.125.204.174	8080	29	10773
10.9.23.102	63414	136.232.34.70	443	19	3323
10.9.23.102	63415	131.253.33.200	443	4	232
10.9.23.102	63416	10.9.23.5	135	13	1518
10.9.23.102	63417	10.9.23.5	49667	13	2042
10.9.23.102	63418	208.91.128.6	80	9	1297
10.9.23.102	63419	136.232.34.70	443	181	114166
10.9.23.102	63421	20.189.173.6	443	23	8377
10.9.23.102	63423	185.125.204.174	8080	27	8501
10.9.23.102	63424	136.232.34.70	443	21	4185
10.9.23.102	63425	136.232.34.70	443	22	3419
10.9.23.102	63426	40.125.122.151	443	56	23307
10.9.23.102	63427	20.189.173.6	443	28	10643
10.9.23.102	63428	208.91.128.6	80	9	1317
10.9.23.102	63429	104.120.107.254	443	24	8605
10.9.23.102	63430	20.189.173.6	443	23	8780
10.9.23.102	63431	52.137.103.130	443	24	5143
10.9.23.102	63432	104.120.111.248	443	23	9106
10.9.23.102	63433	104.120.111.248	443	25	8710
10.9.23.102	63434	104.46.162.224	443	23	8419
10.9.23.102	63437	104.46.162.224	443	25	9228
10.9.23.102	63438	185.125.204.174	8080	23	8236
10.9.23.102	63439	136.232.34.70	443	1002	989600
10.9.23.102	63440	104.46.162.224	443	23	8739
10.9.23.102	63441	208.91.128.6	80	9	1293
10.9.23.102	63442	136.232.34.70	443	16	3068
10.9.23.102	63443	136.232.34.70	443	54	33454
10.9.23.102	63444	208.91.128.6	80	9	1293
10.9.23.102	63445	185.125.204.174	8080	25	8372
10.9.23.102	63446	136.232.34.70	443	19	3261
10.9.23.102	63447	185.106.96.158	80	187	220640
10.9.23.102	63448	185.106.96.158	80	9	1325
10.9.23.102	63449	185.125.204.174	8080	23	8641
10.9.23.102	63450	185.125.204.174	8080	24	8195
10.9.23.102	63451	185.125.204.174	8080	24	8318
10.9.23.102	63452	185.125.204.174	8080	23	8236
10.9.23.102	63453	185.125.204.174	8080	34	13405
10.9.23.102	63454	208.91.128.6	80	9	1325
10.9.23.102	63455	185.125.204.174	8080	24	8296
10.9.23.102	63456	185.125.204.174	8080	25	8440
10.9.23.102	63457	185.125.204.174	8080	389	383218

Figure 3.2.10

In Figure 3.2.7, IP address 208.91.128.6 is observed sending beacon traffic that should elicit a response from the attacker's C2 server. Figures 3.2.9 and 3.2.10 show the corresponding C2 responses from IP addresses 185.125.204.174 and 185.106.96.158, which contain high-volume packets associated with the beacon traffic and are verified by "VirusTotal" as Cobalt Strike servers. In addition, IP address 136.232.34.70 is identified as another C2 server that cooperates with 185.106.96.158 in the following attack. The data is extracted from the Wireshark conversation in Excel format for review.

C2 Server	136.232.34.70	Domain: Hide
Conbalt Strike Server	185.106.96.158	Domain: survmeter.live
Conbalt Strike Server	185.125.204.174	Domain: securitybusinpuuff.com

Figure 3.2.9

3.3 Final Exfiltration/Check-in

After using the zip file to infect the victim's system and establish a stable connection with the C2 server, the malware starts its primary objective. In ZUI, there are a lot of alerts triggered on port 25 starting from 17:02:43, which means that from 16:46:15 (Figure 3.2.8) to 17:02:43 (Figure 3.3.1), something triggered the SMTP alert.

from cw1.pcap							
1 event_type=="alert" fuse sort ts cut ts, sre_ip, dest_ip, src_port, dest_port, alert, app_proto							
ts	sre_ip	dest_ip	src_port	dest_port	alert	app_proto	
2021-09-24T17:02:36.954954Z	> error(missing)	23.21.173.155	63663	443	> {severity: 3, signature: ET INFO External IP Address Lookup Domain (ipify	tls	
2021-09-24T17:02:43.15094Z	> error(missing)	10.9.23.102	25	63678	> {severity: 3, signature: SURICATA Applayer Detect protocol only one direct smtp		
2021-09-24T17:02:44.591912Z	> error(missing)	10.9.23.102	25	63681	> {severity: 3, signature: SURICATA Applayer Detect protocol only one direct smtp		
2021-09-24T17:02:45.96423Z	> error(missing)	10.9.23.102	25	63686	> {severity: 3, signature: SURICATA Applayer Detect protocol only one direct smtp		
2021-09-24T17:02:46.319143Z	> error(missing)	136.232.34.70	63688	443	> {severity: 3, signature: ET JA3 Hash - [Abuse.ch] Possible Dridex ...+6 }	tls	
2021-09-24T17:02:47.754841Z	> error(missing)	136.232.34.70	63692	443	> {severity: 3, signature: ET JA3 Hash - [Abuse.ch] Possible Dridex ...+6 }	tls	
2021-09-24T17:02:48.252307Z	> error(missing)	10.9.23.102	25	63693	> {severity: 3, signature: SURICATA Applayer Detect protocol only one direct smtp		

Figure 3.3.1

In **Figures 3.3.2 and 3.3.3**, a suspicious request to `api.ipify.org` is observed before 17:02:43, with the first query in 2021-09-24T17:00:04. After receiving the beacon, the attacker still does not know the victim's external IP address, which is needed to locate the victim. Therefore, the malware uses `api.ipify.org` to reveal the victim's external IP.

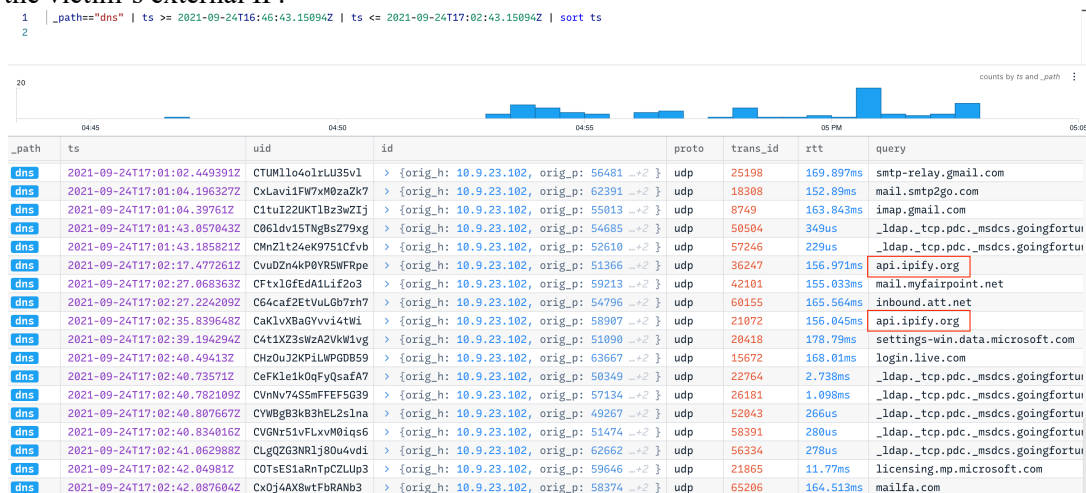


Figure 3.3.2

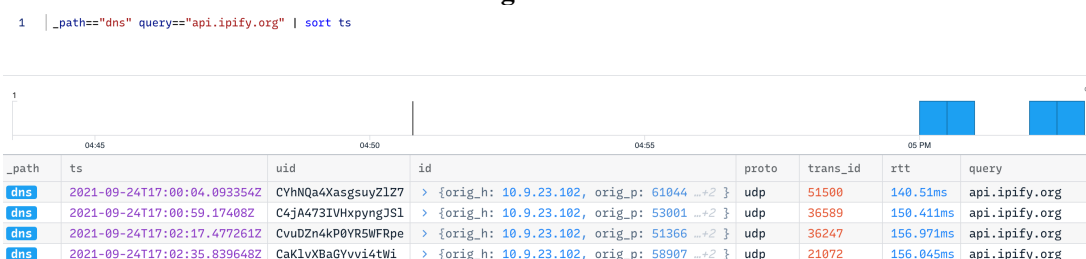


Figure 3.3.3

In **Figure 3.3.4**, the traffic shows an external email login process, the corresponding password, and the first outbound email. This indicates that the attacker has identified the victim and already to send spam through the victim.

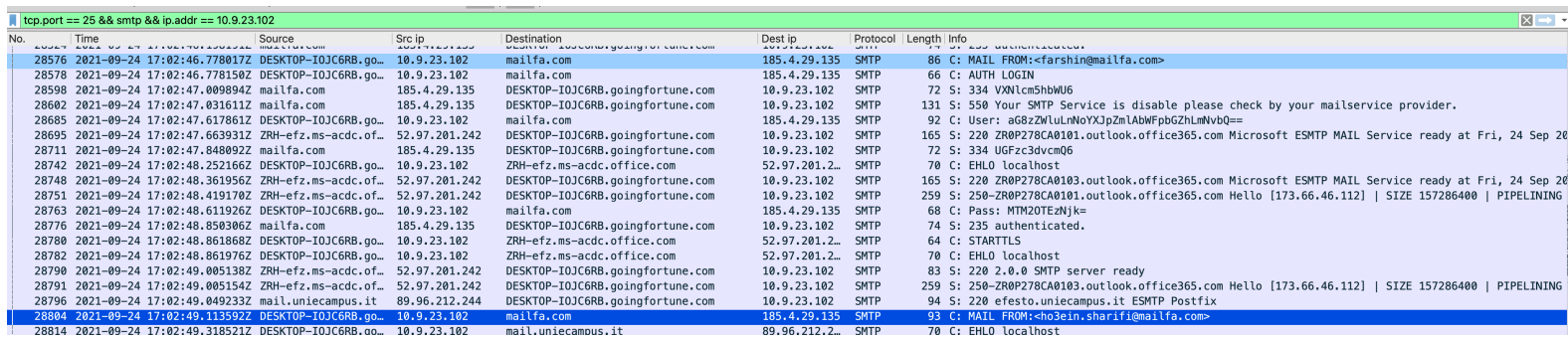


Figure 3.3.4

By following the TCP stream, the findings are as follows:

1. Victim identifies itself to the server
2. Server request authentication
3. Victim submit the username and password
4. Username: ho3ein.sharifi@mailfa.com
5. Password: 13691369 (after Base64 decode)
6. The mail service provider blocks the email

In Figure 3.3.6 show the victim device sending SMTP traffic proves it has become a botnet zombie sending the spam.

Figure 3.3.5

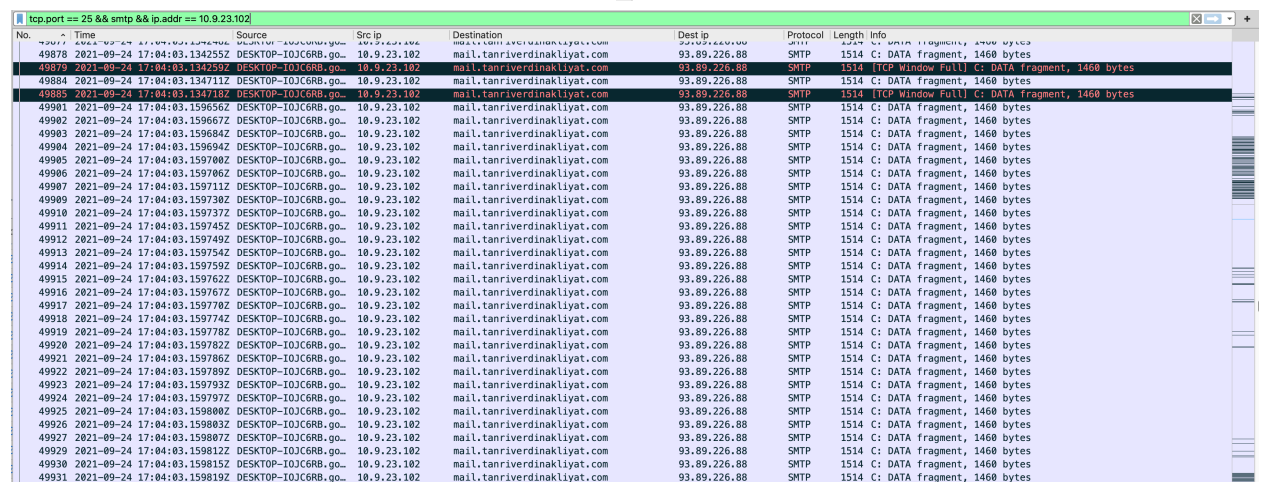


Figure 3.3.6

4. Conclusion

In this incident, the attack follows a SquirrelWaffle infection chain. The victim first downloads a zip file containing a malicious MS Excel file. From pcap, the traffic show after downloaded the file, the embedded trojan is executed and establishes the connection to the C2 server. After the C2 receives the beacon and confirms the victim IP address, it maintains a stable command-and-control channel. Finally, the malware attempts to abuse the compromised host to send email using the account. Initially, the SMTP attempt is blocked with a "550 Your SMTP service is disabled" response from the mail service provider, but in the end the victim device becomes a botnet zombie.

For prevention, since the victim is a user within the organization (goingfortune.com), it is recommended to implement web whitelisting to control which websites can be accessed. In addition, regular phishing awareness training is required. Users should be educated and reminded that, before downloading attachments or clicking links, they must verify that the content is legitimate and safe. The organization can also run periodic phishing drills to test and improve users' resistance to social engineering attacks.

For more details on the figures, please find the GitHub link below:

https://github.com/10957621/COMP3010HK_ASSESSMENT_CW1-CW2.git

For more details of the pcap analysis process, please find the YouTube link below:

<https://youtu.be/qM8bj5DQ8Eo>

5. Appendix

Student Declaration of AI Tool use in this Assessment

Please indicate your level of usage of generative AI for this assessment - please tick the appropriate category(s).

If the “Assisted Work” or “Partnered Work” category is selected, please expand on the usage and in which elements of the assignment the usage refers to.

Solo Work	S1 - Generative AI tools have not been used for this assessment.	☐
Assisted Work	A1 – Idea Generation and Problem Exploration Used to generate project ideas, explore different approaches to solving a problem, or suggest features for software or systems. Students must critically assess AI-generated suggestions and ensure their own intellectual contributions are central.	☐
	A2 - Planning & Structuring Projects AI may help outline the structure of reports, documentation and projects. The final structure and implementation must be the student’s own work.	☐
	A3 – Code Architecture AI tools maybe used to help outline code architecture (e.g. suggesting class hierarchies or module breakdowns). The final code structure must be the student’s own work.	☐
	A4 – Research Assistance Used to locate and summarise relevant articles, academic papers, technical documentation, or online resources (e.g. Stack Overflow, GitHub discussions). The interpretation and integration of research into the assignment remain the student’s responsibility.	☐
	A5 - Language Refinement Used to check grammar, refine language, improve sentence structure in documentation not code. AI should be used only to provide suggestions for improvement. Students must ensure that the documentation accurately reflects the code and is technically correct.	☐
	A6 – Code Review AI tools can be used to check comments within the code and to suggest improvements to code readability, structure or syntax. AI should be used only to provide suggestions for improvement. Students must ensure that the code accurately reflects their knowledge and is technically correct.	☐
	A7 - Code Generation for Learning Purposes Used to generate example code snippets to understand syntax, explore alternative implementations, or learn new programming paradigms. Students must not submit AI-generated code as their own and must be able to explain how it works.	☐
	A8 - Technical Guidance & Debugging Support AI tools can be used to explain algorithms, programming concepts, or debugging strategies. Students may also help interpret error messages or suggest possible fixes. However, students must write, test, and debug their own code independently and understand all solutions submitted.	☐

	A9 - Testing and Validation Support AI may assist in generating test cases, validating outputs, or suggesting edge cases for software testing. Students are responsible for designing comprehensive test plans and interpreting test results.	☐
	A10 - Data Analysis and Visualization Guidance AI tools can help suggest ways to analyse datasets or visualize results (e.g. recommending chart types or statistical methods). Students must perform the analysis themselves and understand the implications of the results.	☐
	A11 - Other uses not listed above Please specify:	☐
Partnered Work	P1 - Generative AI tool usage has been used integrally for this assessment Students can adopt approaches that are compliant with instructions in the assessment brief. Please Specify:	☒

Please provide details of AI usage and which elements of the coursework this relates to:

Details of Usage:

I utilized Generative AI as a technical partner (Category P1) to facilitate the investigation and documentation process for both Coursework 1 Specifically:

- **Wireshark:** The AI provided filter syntax (e.g., smtp) to isolate relevant packets.
- **Zui:** The AI generated query syntax to filter PCAP data, such as isolating HTTP GET requests (_path=="http") and specific timeframes for C2 traffic.
- It was used to refine the professional tone and check English grammar for the final PDF report.
- The AI explained technical concepts such as SQUIRRELWAFFLE, Cobalt Strike.

I personally verified all AI-generated outputs (timestamps, IP addresses, file names, and decoded credentials) using the respective tools (Wireshark, Zui) before including them in the final submission.

I understand that the ownership and responsibility for the academic integrity of this submitted assessment falls with me, the student.	☒
I confirm that all details provide above are an accurate description of how AI was used for this assessment.	☒

OR HOI CHUEN

OR Hoichuen
10957621

6. References

1. Jayanand, N. (2025, April 27). *SquirrelWaffle Malware: Infection methods and protection*. SentinelOne. <https://www.sentinelone.com/blog/is-squirrelwaffle-the-new-emet-how-to-detect-the-latest-malspam-loader/>
2. <https://www.virustotal.com/gui/home/url>